



HACKTHEBOX

Bug Bounty Program

Trilocor Private Web Application

Report of Findings

HTB Certified Bug Bounty Hunter (CBBH) Exam Report

Candidate Name: TODO Candidate Name

Trilocor Robotics Ltd.

May 31, 2023

Version: 1.0

Table of Contents

1	Statement of Confidentiality	3
2	Engagement Contacts	4
3	Executive Summary	5
3.1	Approach	5
3.2	Scope	5
3.3	Assessment Overview and Recommendations	6
4	Web Application Assessment Summary	7
4.1	Summary of Findings	7
5	Technical Findings Details	8
	SQL Injection	8
	Username Enumeration	9
	Cookie Missing Secure Flag	10
A	Appendix	11
A.1	Flags Discovered	11

1 Statement of Confidentiality

The contents of this document have been developed by Hack The Box. Hack The Box considers the contents of this document to be proprietary and business confidential information. This information is to be used only in the performance of its intended use. This document may not be released to another vendor, business partner or contractor without prior written consent from Hack The Box. Additionally, no portion of this document may be communicated, reproduced, copied or distributed without the prior consent of Hack The Box.

The contents of this document do not constitute legal advice. Hack The Box's offer of services that relate to compliance, litigation or other legal interests are not intended as legal counsel and should not be taken as such. The assessment detailed herein is against a fictional company for training and examination purposes, and the vulnerabilities in no way affect Hack The Box external or internal infrastructure.

2 Engagement Contacts

Trilocor Contacts		
Contact	Title	Contact Email
TODO Name	TODO Title	TODO Email
TODO Name	TODO Title	TODO Email

Assessor Contact		
Assessor Name	Title	Assessor Contact Email
TODO Candidate Name	TODO Candidate Title	TODO Candidate Email

3 Executive Summary

Trilocor Robotics Ltd. ("Trilocor" herein) invited TODO Candidate Name to a private bug bounty program to perform a targeted Web Application Penetration Test of Trilocor's externally facing web applications to identify high-risk security weaknesses, determine the impact to Trilocor, document all findings in a clear and repeatable manner, and provide remediation recommendations. The following types of findings were in-scope for this private bug bounty program:

- Sensitive or personally identifiable information disclosure
- Cross-Site Scripting (XSS)
- Server-side or remote code execution (RCE)
- Arbitrary file upload
- Authentication or authorization flaws, such as insecure direct object references (IDOR), and authentication bypasses
- All forms of injection vulnerabilities
- Directory traversal
- Local file read
- Significant security misconfigurations and business logic flaws
- Exposed credentials that could be leveraged to gain further access

The following types of activities were considered out-of-scope for this bug bounty program:

- Scanning and assessing any other IP in the Entry Point's network
- Physical attacks against Trilocor properties
- Unverified scanner output
- Man-in-the-Middle attacks
- Any vulnerabilities identified through DDoS or spam attacks
- Self-XSS
- Login/logout CSRF
- Issues with SSL certificates, open ports, TLS versions, or missing HTTP response headers
- Vulnerabilities in third party libraries unless they can be leveraged to significantly impact the target
- Any theoretical attacks or attacks that require significant user interaction or low risk

TODO Candidate Name performed testing under a "Black Box" approach from May 12, 2023, to May 31, 2023 without credentials or any advance knowledge of Trilocor's web applications with the goal of identifying unknown weaknesses. Testing was performed from a non-evasive standpoint with the goal of uncovering as many misconfigurations and vulnerabilities as possible. Testing was performed remotely. Each weakness identified was documented and manually investigated to determine exploitation possibilities and escalation potential. TODO Candidate Name sought to demonstrate the full impact of every vulnerability, up to and including internal network access.

3.1 Approach

3.2 Scope

The scope of this assessment was as follows TODO *.trilocor.local and any and all open web server ports discovered on the target IP address provided at the start of the assessment.

In Scope Assets

Host/URL/IP Address	Description
TODO www.trilocor.local	Main Trilocor website/unauthenticated
TODO exam IP address	PR website/unauthenticated
TODO exam IP address	Jobs Portal/unauthenticated
TODO exam IP address	HR website/unauthenticated
TODO exam IP address	Trilocor online store/unauthenticated

3.3 Assessment Overview and Recommendations

During the course of testing against TODO Candidate Name identified ...

TODO SUMMARY OF FINDINGS AND RECOMMENDATIONS HERE

4 Web Application Assessment Summary

TODO Candidate Name began all testing activities from the perspective of an unauthenticated user on the internet. Trilocor provided the tester with a single URL and IP address but did not provide additional information such as operating system or configuration information.

4.1 Summary of Findings

During the course of testing, TODO Candidate Name uncovered a total of 3 findings that pose a material risk to Trilocor's information systems. The below chart provides a summary of the findings by severity level.

In the course of this penetration test **1 Critical**, **1 Medium** and **1 Low** vulnerabilities were identified:

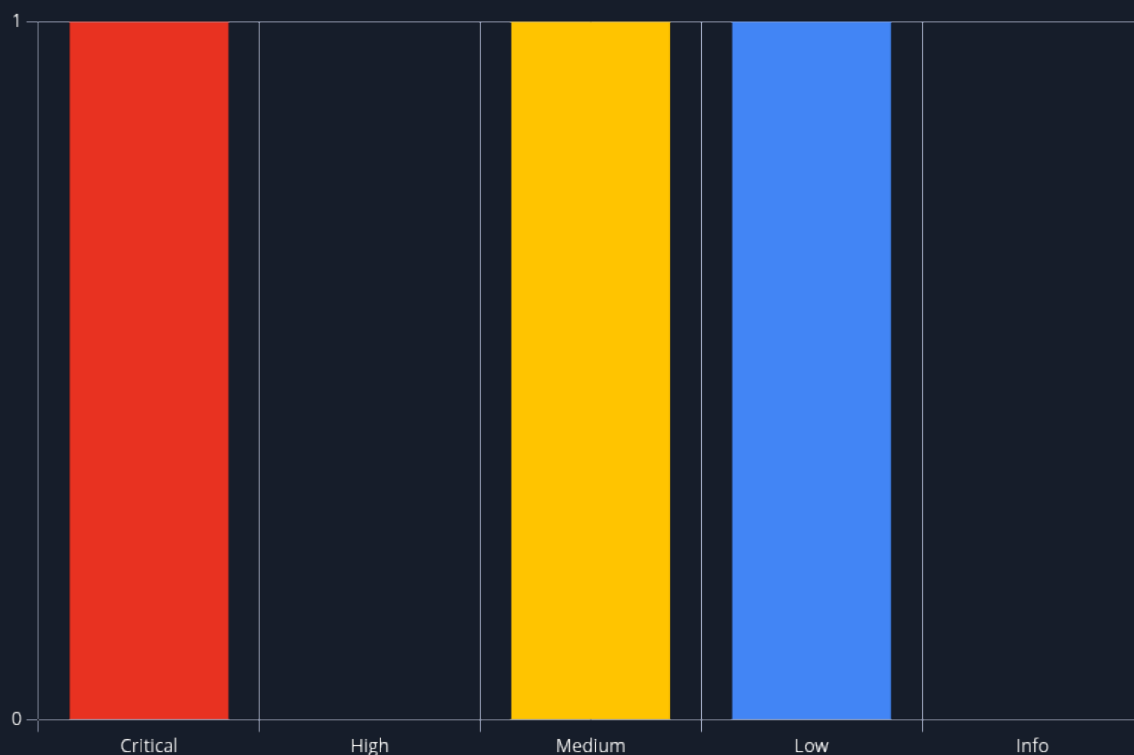


Figure 1 - Distribution of identified vulnerabilities

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

#	Severity Level	Finding Name	Page
1	9.9 (Critical)	SQL Injection	8
2	6.4 (Medium)	Username Enumeration	9
3	3.1 (Low)	Cookie Missing Secure Flag	10

5 Technical Findings Details

1. SQL Injection - Critical

CWE	CWE-89 - Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
CVSS 3.1	9.9 / CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H
Root Cause	The application does not properly sanitize input data, allowing an unauthenticated attacker to inject SQL code into database queries. TODO EXAMPLE FINDING
Impact	A successful SQL injection attack can result in access to sensitive data from the database, modifications to database data (Insert/Update/Delete), execution of administration operations on the database (such as shutting down the DBMS), recovering the contents of a given file present on the DBMS file system and in some cases issuing commands on the underlying operating system.
Affected Component	mytestsite.com, Id parameter
Remediation	Where possible, use parameterized queries to ensure that database interactions cannot be contaminated. Also, escape all user supplied input/utilize a whitelist of approved characters to validate all input that is passed to the database.
References	https://www.owasp.org/index.php/SQL_Injection_Prevention_Cheat_Sheet

Finding Evidence

Note to candidate: Finding evidence should include detailed reproduction steps, showing how you discovered the vulnerability, exploitation steps, and a screenshot showing the flag obtained using the vulnerability (if it resulted in discovery of a flag). It should be possible to easily recreate each finding from the evidence & steps you provide. If you are having trouble with reporting or would like to see a sample of the type of report we expect for a passing grade, check out the Documentation and Reporting module on HTB Academy.

TODO INSERT REPRODUCTION STEPS AND SCREENSHOTS AS APPROPRIATE

2. Username Enumeration - Medium

CWE	CWE-89 - Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
CVSS 3.1	6.4 / CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:L/A:N
Root Cause	TODO DESCRIPTION
Impact	TODO IMPACT
Affected Component	TODO AFFECTED COMPONENT
Remediation	TODO REMEDATION
References	TODO REFERENCES

Finding Evidence

ADD COMMAND OUTPUT AS APPROPRIATE

TODO ADD SCREENSHOTS AS APPROPRIATE

3. Cookie Missing Secure Flag - Low

CWE	CWE-89 - Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
CVSS 3.1	3.1 / CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:N/A:N
Root Cause	TODO DESCRIPTION
Impact	TODO IMPACT
Affected Component	TODO AFFECTED COMPONENT
Remediation	TODO REMEDIATION
References	TODO REFERENCES

Finding Evidence

ADD COMMAND OUTPUT AS APPROPRIATE

TODO ADD SCREENSHOTS AS APPROPRIATE

A Appendix

A.1 Flags Discovered

Flag #	Application	Flag Value	Flag Location	Method Used
1. TODO	Main	HTB random value	Web root	Command Injection (example)
2.				
3.				
4.				
5.				
6.				
7.				
8.				
9.				
10.				

End of Report

*This report was rendered
by SysReptor with
♥*